

ReportOps + Auto-Audit (CIS AlmaLinux 9) – Tổng hợp kiến trúc & checklist triển khai

Tổng hợp những gì cần để triển khai ReportOps + Auto-Audit CIS AlmaLinux 9

Tài liệu này gom toàn bộ yêu cầu, kiến trúc, module, công nghệ, dữ liệu, quy trình CI/CD để bạn có thể triển khai web app hợp nhất gồm:

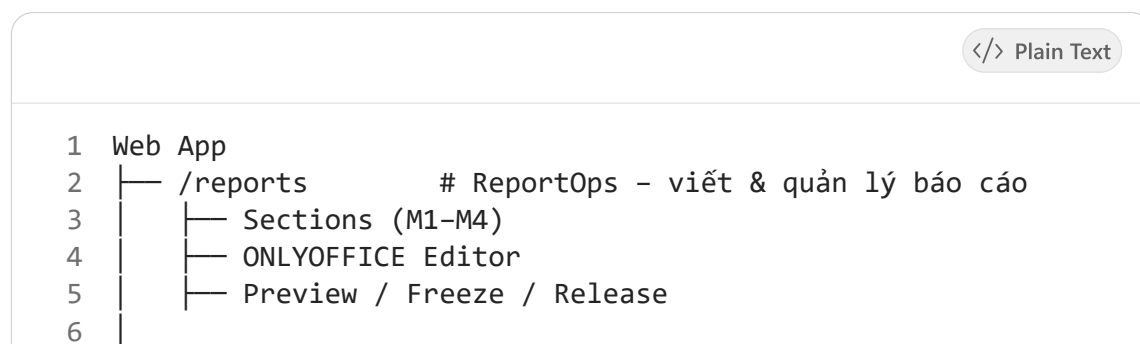
- **Hướng cũ: ReportOps** (viết báo cáo theo phần, ONLYOFFICE, release)
- **Hướng mới: Auto-Audit** (audit tự động theo CIS AlmaLinux OS 9 Benchmark v2.0.0 – Level 1 Server)

Tài liệu đã **map đúng phân chia công việc M1–M4** theo các đề mục 1.x, 2.x, ... trong benchmark mà bạn gửi.

0. Phạm vi & nguyên tắc chốt

- **Source of truth nội dung:** Database + Object Storage (không dùng Git làm nơi sửa live)
- **Editor:** ONLYOFFICE Docs Developer (UX gần Word)
- **Audit engine:** OpenSCAP + SCAP Security Guide (CIS AlmaLinux 9 L1 Server)
- **GitHub:** Login (OAuth), Release/Archive, CI/CD, Project metadata (không lưu nội dung live)
- **Mỗi người chỉ sửa 1 phần** → giảm xung đột, đơn giản hoá quyền
- **Audit chỉ đọc (read-only)** ở MVP, không auto-remediate

1. Bản đồ chức năng tổng thể (Functional Map)



```

7 | — /audit          # Auto-Audit CIS
8 |   | — Targets (IP/Host)
9 |   | — Credentials (Vault)
10 |  | — Benchmark & Controls
11 |  | — Run Audit
12 |  | — Results Dashboard
13 |
14 | — /releases      # Artifacts, PDF, audit reports
15 | — /admin        # Users, RBAC, mapping M1-M4
16 | — /api          # Backend APIs
17

```

2. Mapping phân chia công việc M1–M4 ↔ CIS Benchmark

✓ M1 – Initial Setup / Filesystem / Package / Boot / Crypto / Time / Scheduler

CIS Sections:

- 1.1 Filesystem (kernel modules, partitions)
- 1.2 Package Management
- 1.4 Bootloader
- 1.5 Process Hardening
- 1.6 Crypto Policy
- 2.3 Time Synchronization
- 2.4 Job Schedulers (cron/at)

Owner trong hệ thống: `section_key = M1`

✓ M2 – SELinux / Services / Network / Firewall

CIS Sections:

- 1.3 Mandatory Access Control (SELinux)

- 2.1 Server Services
- 2.2 Client Services
- 3.x Network Configuration
- 4.x Host-based Firewall (firewalld / nftables)

Owner: `section_key = M2`

✓ M3 – SSH / Privilege Escalation / PAM / User Accounts

CIS Sections:

- 5.1 SSH Server
- 5.2 Privilege Escalation (sudo)
- 5.3 PAM
- 5.4 User Accounts & Environment

Owner: `section_key = M3`

✓ M4 – Banners / GDM / Logging & Auditing / System Maintenance

CIS Sections:

- 1.7 Warning Banners
- 1.8 GDM
- 6.x Logging & Auditing (auditd, journald, rsyslog)
- 7.x System Maintenance

Owner: `section_key = M4`

3. Kiến trúc kỹ thuật (Production-ready, MVP-friendly)

3.1 Frontend

- Next.js (App Router)
 - Deploy: Vercel
 - UI: shadcn/ui hoặc design system riêng
 - Routes:
 - `/reports`
 - `/audit`
 - `/releases`
 - `/admin`
-

3.2 Backend (Vercel implementation)

- Vercel Functions cho:
 - Auth (GitHub OAuth)
 - RBAC
 - ReportOps APIs
 - Audit job orchestration
 - Không chạy SSH/OpenSCAP trực tiếp trong Vercel Function
-

3.3 Audit Runner (bắt buộc tách riêng)

```
1 Audit Runner (Docker / VM / K8s Job)
2   └─ SSH client
3   └─ OpenSCAP
4   └─ scap-security-guide (AlmaLinux 9)
5   └─ Result normalizer
6   └─ Uploader (Blob + DB)
7
```

- Nhận job từ queue
- SSH vào target
- Chạy `oscap xccdf eval` với profile:

- `cis_server_11`
 - Xuất:
 - `results.xml`
 - `report.html`
 - `normalized.json`
-

3.4 Database (Postgres)

Core tables:

- `users`
 - `roles`
 - `sections` (M1–M4)
 - `documents`
 - `document_versions`
 - `audit_targets`
 - `audit_jobs`
 - `audit_controls`
 - `audit_results`
 - `releases`
-

3.5 Document & Artifact Storage

- Vercel Blob (private) hoặc S3/R2

`</>` Plain Text

```
1 /sections/M1/current.docx
2 /sections/M2/current.docx
3 /reports/preview/report-xxx.docx
4 /audits/job-123/report.html
5 /audits/job-123/results.json
6
```

3.6 Editor – ONLYOFFICE

- ONLYOFFICE Docs Developer (self-host)
 - Web app chỉ **embed editor**, backend cấp config
 - Callback save → lưu version
-

3.7 GitHub Integration

- **GitHub OAuth App**: login
 - **GitHub Releases**: lưu final artifacts
 - **GitHub Actions**:
 - CI
 - Security scan
 - Release
 - **GitHub Project**: optional sync status
-

4. Module ReportOps (hướng cũ – đã ổn)

Chức năng

- Mỗi member edit **1 section**
- Versioning
- Preview tổng hợp
- Freeze / Release

Main Report = Generated Artifact

- Không edit trực tiếp
- Build từ M1–M4 .docx

5. Module Auto-Audit (hướng mới)

5.1 UI /audit

1. Target Setup

- IP / Hostname
- SSH port
- Username
- Auth: key / password

2. Benchmark Selection

- CIS AlmaLinux OS 9 v2.0.0
- Level 1 Server
- Audit all / selected controls

3. Run Audit

- Preflight SSH
- Progress

4. Result Dashboard

- Compliance score
 - PASS / FAIL / N/A / MANUAL
 - Risk level
 - Export HTML / JSON / PDF
-

5.2 Audit States

`</>` Plain Text

```
1 PASS | FAIL | NOT_APPLICABLE | MANUAL | ERROR
2
```

5.3 Risk Scoring (đề xuất)

</> Plain Text

```
1 Compliance % = pass / applicable * 100
2
3 Risk Weight:
4 - M1: 3-4
5 - M2: 4-5
6 - M3: 5
7 - M4: 4
8
```

5.4 Gắn audit vào ReportOps

- Mỗi control có `owner_section_key` (M1-M4)
- Báo cáo cuối có:
 - Audit Summary
 - Bảng failed controls theo M1-M4

6. Bảo mật & DevSecOps (bắt buộc)

- Không log credential
 - Credential TTL
 - Vault / encrypted secrets
 - Audit log mọi action
 - Allowlist IP
 - SSH host key verify
 - Không auto-remediate ở MVP
-

7. CI/CD & GitOps Blueprint

Repo structure

```
1 reportops/
2 |─ apps/web
3 |─ packages/
4 |   │─ audit-engine
5 |   │─ report-generator
6 |   │─ db
7 |   └─ shared
8 |─ infra/
9 |   │─ onlyoffice/
10 |   │─ audit-runner/
11 └─ .github/workflows
12
```

</> Plain Text

Pipelines

- `ci.yml` – lint, test
 - `security.yml` – SAST, secrets, deps
 - `release.yml` – build + GitHub Release
 - `nightly-preview.yml`
-

8. MVP Roadmap (rất thực tế)

Phase 1 – Core Platform

- GitHub login + RBAC
- Section docs + ONLYOFFICE

Phase 2 – ReportOps

- Preview + Freeze + Release

Phase 3 – Auto-Audit MVP

- Audit runner
- CIS AlmaLinux 9 L1
- Dashboard

Phase 4 – Integration

- Audit → Report
 - Release bundle
-

9. Những gì bạn cần chuẩn bị ngay (Checklist)

Kỹ thuật

GitHub OAuth App

Vercel project

Postgres

Object Storage

ONLYOFFICE server

Audit Runner host

Nội dung

Mapping M1–M4 ↔ CIS controls

Owner assignment

Quy trình

CI/CD

Security scanning

Release rules

10. Kết luận

Bạn không cần đổi hướng nữa. Kiến trúc này:

- Phù hợp bài tập + thực tế DevSecOps
 - Dùng CIS chuẩn
 - Kết hợp manual report + automated audit
 - Scale tốt nếu làm tiếp luận văn / project lớn
-

👉 Bước tiếp theo mình có thể làm ngay:

1. Sinh schema DB + API contract chi tiết
2. Sinh repo scaffold (monorepo) đầy đủ
3. Sinh mapping bảng CIS → JSON controls cho OpenSCAP

Bạn chỉ cần nói: "Làm tiếp bước X"